

Security Assessment

Vulnerability & Penetration Testing Report

Report ID	611fa75c	Generated	May 26, 2026
Target	https://octane.stpi.in/	Classification	CONFIDENTIAL

CONFIDENTIAL • AUTHORIZED USE ONLY

Executive Summary

The vulnerability assessment of <https://octane.stpi.in/> has identified CRITICAL security exposures requiring immediate remediation. 0 critical and 3 high severity issues present a substantial risk to data confidentiality, system integrity, and service availability. Exploitation of the identified critical vulnerabilities may result in full system compromise or exfiltration of sensitive data. Immediate action is strongly recommended.

Detailed Findings

#001 Missing Content-Security-Policy Header

HIGH CVSS 7.5
[CONFIRMED BY SAST + DAST]

The response from <https://octane.stpi.in/> is missing the 'content-security-policy' security header. This reduces browser-level protection against common attack classes.

Remediation: Add CSP: Content-Security-Policy: default-src 'self'; script-src 'self'

#002 Missing HSTS Header

HIGH CVSS 7.5 [SAST]

HTTP Strict Transport Security not set — SSL stripping attacks possible.

Remediation: Add: Strict-Transport-Security: max-age=31536000; includeSubDomains

#003 Sensitive Data Exposed in Response: possible credit card number

HIGH CVSS 7.5 [DAST]

The response at '<https://octane.stpi.in/>' contains possible credit card number. Sensitive values must never be returned in API responses unnecessarily. This data can be captured by a MITM or I

Remediation: Remove sensitive fields from API responses. Apply field-level encryption for PII. Never return credentials, keys, or tokens in responses.

#004 Missing HSTS Header

MEDIUM CVSS 5.9
[DAST]

The HTTPS endpoint '<https://octane.stpi.in/>' does not send the Strict-Transport-Security header. Without HSTS, browsers may connect over HTTP on subsequent visits, enabling SSL-stripping attac

Remediation: Add: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

#005 Missing X-Content-Type-Options Header**MEDIUM CVSS 5.3**
[CONFIRMED BY SAST + DAST]

The response from <https://octane.stpi.in/> is missing the 'x-content-type-options' security header. This reduces browser-level protection against common attack classes.

Remediation: Add: X-Content-Type-Options: nosniff

#006 Missing X-Frame-Options Header**MEDIUM CVSS 5.3**
[CONFIRMED BY SAST + DAST]

The response from <https://octane.stpi.in/> is missing the 'x-frame-options' security header. This reduces browser-level protection against common attack classes.

Remediation: Add: X-Frame-Options: DENY (or use CSP frame-ancestors)

#007 Cookie Missing HttpOnly Flag**MEDIUM CVSS 6.5**
[SAST]

Session cookie accessible to JavaScript — theft via XSS possible.

Remediation: Add HttpOnly flag to all session cookies.

#008 Mixed Content — HTTP Resources on HTTPS Page**MEDIUM CVSS 5.9**
[DAST]

The HTTPS page at '<https://octane.stpi.in/>' loads 3 resource(s) over plain HTTP. Mixed content allows attackers to intercept or modify these resources, potentially injecting malicious scripts

Remediation: Update all resource URLs to use HTTPS. Add Content-Security-Policy: upgrade-insecure-requests or block-all-mixed-content directives.

#009 Session Cookie Missing HttpOnly Flag**MEDIUM CVSS 6.5**
[DAST]

Set-Cookie header at <https://octane.stpi.in/> is missing the 'httponly' attribute.

Remediation: Add HttpOnly to all session cookies.

#010 Subresource Integrity (SRI) Attribute Missing**MEDIUM CVSS 5.5**
[DAST]

Found 4 external script/link tag(s) at <https://octane.stpi.in/> without an integrity attribute. Without SRI, if the external CDN is compromised, malicious code could be injected into your pages.

Remediation: Add integrity and crossorigin attributes to all external scripts/links: . Generate hashes at: <https://www>

#011 Missing Referrer-Policy**LOW CVSS 2.7**
[CONFIRMED BY SAST + DAST]

The response from <https://octane.stpi.in/> is missing the 'referrer-policy' security header. This reduces browser-level protection against common attack classes.

Remediation: Add: Referrer-Policy: strict-origin-when-cross-origin

#012 Missing Permissions-Policy**LOW CVSS 2.7**
[CONFIRMED BY SAST + DAST]

The response from <https://octane.stpi.in/> is missing the 'permissions-policy' security header. This reduces browser-level protection against common attack classes.

Remediation: Add Permissions-Policy to disable unneeded browser APIs

#013 Server Technology Version Disclosed: Microsoft-IIS/8.5**LOW CVSS 2.7 [DAST]**

The 'server' header reveals the server technology and version: 'Microsoft-IIS/8.5'. Attackers can use this to target known CVEs for that specific version.

Remediation: Remove or generalise the 'server' header in server configuration.

#014 Server Version Disclosure**LOW CVSS 2.7 [SAST]**

Server header exposes version: Microsoft-IIS/8.5

Remediation: Remove or obfuscate the Server header.

#015 Session Cookie Missing SameSite**LOW CVSS 4.2 [DAST]**

Set-Cookie header at <https://octane.stpi.in/> is missing the 'samesite' attribute.

Remediation: Add SameSite=Strict or Lax to session cookies.

#016 Password Field Allows Autocomplete**LOW CVSS 4.2 [DAST]**

A password input at <https://octane.stpi.in/stylesheets/style.css> does not have autocomplete='off'. Browsers may cache credentials and expose them to other users on shared devices.

Remediation: Add autocomplete='off' or autocomplete='new-password' to all password fields.